

Item 2 — Tipos de Usuários e Permissões

Prompt

Você é um arquiteto de software trabalhando na Phase B (Business Architecture) do TOGAF ADM.

Contexto:

- Domínio: app web de descoberta e tracking de video games (estilo Letterboxd para jogos).
- Catálogo vem da RAWG Video Games Database API; dados do usuário (biblioteca, reviews, listas, follows) ficam em backend próprio.
- As funcionalidades core já definidas: busca de jogos, página de detalhes, biblioteca pessoal com status, avaliação/review, listas customizadas, recomendações, feed de lançamentos, perfil público com estatísticas, social (follow + atividade) e wishlist com alertas.
- Modelo de autorização desejado: RBAC (Role-Based Access Control), com papéis mutuamente compostos e permissões granulares por recurso.

Tarefa:

Defina os tipos de usuários (papéis/roles) do sistema e suas permissões.

1. Liste os papéis (sugestão: Visitante, Usuário registrado, Moderador, Administrador). Para cada um, escreva 1 frase descrevendo quem é e seu objetivo no sistema.
2. Produza uma matriz de permissões: linhas = recursos/ações principais (ex: buscar jogos, ver detalhes, gerenciar própria biblioteca, criar review, moderar conteúdo reportado, gerenciar usuários, configurar integração RAWG); colunas = papéis. Use ☒ (permitido), ☐ (negado) e, quando aplicável, "próprio" (só sobre recursos do próprio usuário).
3. Liste de 3 a 5 regras de negócio de autorização relevantes (ex: ownership de conteúdo, visibilidade de listas privadas, escalada de papéis, soft-delete por moderador).

Restrições:

- Papéis devem ser hierárquicos/cumulativos quando fizer sentido (Admin herda capacidades de Moderador, que herda de Usuário registrado).
- Não invente integrações externas além da RAWG API.
- Toda ação de escrita exige usuário autenticado; Visitante é estritamente read-only do conteúdo público.

Formato de saída:

- Seção "Papéis": lista Markdown - **Papel**: descrição .
- Seção "Matriz de permissões": tabela Markdown.
- Seção "Regras de negócio de autorização": lista numerada.

Output (rascunho, validar e refinar com a ferramenta)

Papéis

- **Visitante**: usuário não autenticado que apenas consome conteúdo público (busca, detalhes de jogos, perfis e listas públicas).

- **Usuário registrado (Jogador):** usuário autenticado que gerencia a própria biblioteca, reviews, listas, wishlist e relações sociais.
- **Moderador:** usuário registrado com poder de moderar conteúdo gerado por terceiros (reviews, listas, denúncias), sem acesso a configuração de sistema.
- **Administrador:** papel máximo, gerencia usuários, papéis e a integração com a RAWG API, herdando todas as capacidades de Moderador.

Matriz de permissões

#	Recurso / Ação	Visitante	Usuário registrado	Moderador	Administrador
1	Buscar jogos / ver detalhes (catálogo RAWG)	✓	✓	✓	✓
2	Ver perfis e listas públicas	✓	✓	✓	✓
3	Gerenciar própria biblioteca (status, notas)	✗	✓ próprio	✓ próprio	✓ próprio
4	Criar / editar / excluir review	✗	✓ próprio	✓ próprio	✓ próprio
5	Criar listas customizadas (públicas/privadas)	✗	✓ próprio	✓ próprio	✓ próprio
6	Seguir usuários / interagir socialmente	✗	✓	✓	✓
7	Gerenciar wishlist e alertas	✗	✓ próprio	✓ próprio	✓ próprio
8	Denunciar conteúdo	✗	✓	✓	✓
9	Moderar conteúdo reportado (ocultar/remover)	✗	✗	✓	✓
10	Suspender / banir usuários	✗	✗	✓	✓
11	Gerenciar usuários e atribuir papéis	✗	✗	✗	✓
12	Configurar integração RAWG (chave, sync)	✗	✗	✗	✓

Regras de negócio de autorização

1. **Ownership:** usuário registrado só pode editar/excluir biblioteca, reviews, listas e wishlist que sejam seus; tentativas sobre recursos de terceiros retornam 403.
2. **Visibilidade:** listas e itens de biblioteca marcados como privados só são visíveis ao dono e a Administradores; nunca a Visitantes.
3. **Hierarquia cumulativa:** Administrador herda todas as permissões de Moderador, que herda de Usuário registrado; permissões nunca são reduzidas ao subir de papel.
4. **Soft-delete moderado:** Moderador oculta conteúdo de terceiros (soft-delete com motivo registrado), mas não apaga fisicamente nem edita o conteúdo do usuário.
5. **Atribuição de papéis restrita:** apenas Administrador concede/revoga papéis, e nenhum usuário pode elevar o próprio papel.

Critérios de aceite

- ☐ Pelo menos 3 papéis definidos, com Visitante read-only e separação clara entre Usuário, Moderador e Admin
- ☐ Matriz de permissões cobre todas as funcionalidades core do item 1
- ☐ Distinção "próprio" vs global aplicada às ações de escrita

- ☐ Papéis hierárquicos/cumulativos (Admin $\supseteq$ Moderador $\supseteq$ Usuário)
- ☐ 3 a 5 regras de negócio de autorização, incluindo ownership e visibilidade de conteúdo privado
- ☐ Nenhuma permissão depende de integração externa além da RAWG API

Ferramenta utilizada: Claude (Anthropic), modelo Opus 4.8.